

VindobonaPay GmbH — Control Test Plan

Deliverable 06 | Testing of control design and operating effectiveness | Simulated test period: H1 2026 | Version 2.0 | Fictional company for educational purposes

#	Control (Annex A)	Control objective	Test type	Test procedure	Population	Sample size and rationale	Frequency	Evidence required	Control owner	Tester
CT-01	A.8.2 / A.8.5 — Privileged access rights and secure authentication	All privileged accounts authenticate with phishing-resistant multi-factor authentication — a FIDO2 security key or certificate-based authentication. TOTP authenticator apps and SMS are not accepted as strong methods for privileged access.	Design + Operating effectiveness	Assess whether the policy defines which authentication methods are acceptable for privileged access. Obtain the list of privileged accounts and the MFA enrollment export, compare the two and identify accounts without MFA or using a method that is not phishing-resistant. The comparison step is automated with a Python script (see repository).	12 privileged accounts	12 (100% — small population, all items tested)	Quarterly	Privileged account list; MFA enrollment export; script output (results and exceptions CSV)	IT Manager	CISO
CT-02	A.8.5 — Secure authentication (all users)	MFA is enforced for all user accounts through conditional access.	Design + Operating effectiveness	Review the conditional access policy configuration and confirm it covers all users with no unmanaged exclusions. Select a sample of users and verify their MFA registration status.	85 user accounts	15 (sample for a continuously operating control)	Yearly	Conditional access policy export; MFA registration report	IT Manager	CISO
CT-03	A.5.18 — Access rights review	Access rights to payment and administrative systems are reviewed and confirmed every quarter.	Design + Operating effectiveness	Confirm that a documented review procedure exists and defines reviewers, scope and evidence requirements. For the quarters in scope, obtain the review records and verify sign-off and follow-up of removals.	4 quarterly reviews	2 (selected for a quarterly control, considering the small population)	Yearly	Access review procedure; review records with reviewer sign-off; evidence of access removals	CISO	Compliance Officer
CT-04	A.8.13 — Information backup	Backups run as scheduled and restores are tested periodically with documented results.	Design + Operating effectiveness	Confirm that the backup policy defines schedule, retention and restore testing. Obtain the backup job history and the restore test records; verify that restore tests were performed and that failures were followed up.	4 quarterly restore tests	2 (selected for a quarterly control, considering the small population)	Yearly	Backup job history; restore test reports	IT Manager	CISO
CT-05	A.6.3 — Security awareness and training	All staff complete security awareness training, and new joiners are trained within 30 days.	Design + Operating effectiveness	Confirm that the training policy defines the 30-day requirement for new joiners. Obtain the training completion report and the list of new joiners in the period; verify completion and timeliness for the sample.	85 employees (18 new joiners)	15 (sample across staff and new joiners, weighted towards new joiners)	Yearly	Training completion report; new joiner list; phishing simulation results	HR Manager	CISO
CT-06	A.5.11 — Return of assets and access removal on termination	On termination, accounts are disabled and company assets are returned within the defined timeframe.	Design + Operating effectiveness	Assess whether the offboarding process defines a timeframe and a reliable trigger for account disabling. Obtain the list of leavers in the period; for the sample, compare the termination date with the account disable date and the asset return record.	14 leavers	10 (sample of a low-volume, high-impact control)	Yearly	HR leaver list; account disable logs; offboarding checklists	HR Manager	Compliance Officer
CT-07	A.8.7 — Protection against malware	Endpoint detection and response is installed, active and reporting on all managed endpoints.	Design + Operating effectiveness	Assess whether the process defines monitoring of agent health. Compare the asset inventory with the EDR console export and identify devices missing the agent or not reporting within the last 14 days.	92 managed endpoints	92 (100% — full population available from system exports)	Quarterly	Asset inventory; EDR console export with last check-in dates	IT Manager	CISO
CT-08	A.8.24 / A.7.9 — Encryption of endpoints	Full-disk encryption is enabled on all company laptops.	Design + Operating effectiveness	Confirm that encryption is required by policy and enforced through device management. Export the encryption compliance report and identify non-compliant devices.	92 managed endpoints	92 (100% — full population available from system exports)	Quarterly	Device management encryption compliance report	IT Manager	CISO

Sampling is illustrative and risk-based. Sample sizes were selected for this fictional exercise considering the control frequency, population size, level of automation and associated risk. They are not presented as universal audit thresholds.

Test of design asks whether the control, as described, would prevent or detect the risk. Test of operating effectiveness asks whether the control operated as intended during the simulated review period, based on fictional evidence. If a control is not adequately designed, formal operating-effectiveness testing is normally not meaningful until the design weakness is addressed — although limited evidence may still be reviewed to understand the issue and support remediation.

Tester independence: the tester is assumed to be independent from the control owner and from the activities being tested. In an organization of this size this does not mean a dedicated internal audit department — only that the test is performed by a function other than the one operating the control. The 'Control owner' and 'Tester' columns are shown side by side so this can be verified.

Strong authentication method: for the purposes of CT-01, a strong method means phishing-resistant multi-factor authentication — a FIDO2 security key or certificate-based authentication. TOTP authenticator apps and SMS are not accepted as strong methods for privileged access.

Evidence Request List

What is requested, from whom, and for which test. Sent to control owners before testing starts.

#	Evidence	Source system / document	Requested from	Format	Related test
E-01	List of privileged accounts	Identity platform (Entra ID) export	IT Manager	CSV	CT-01
E-02	MFA enrollment report (including registered method type)	Identity platform (Entra ID) export	IT Manager	CSV	CT-01, CT-02
E-03	Conditional access policy configuration	Identity platform (Entra ID)	IT Manager	Export / screenshot	CT-02
E-04	Access review procedure	ISMS documentation	CISO	Document	CT-03
E-05	Access review records with sign-off	Ticketing system / shared drive	IT Manager	Document	CT-03
E-06	Backup job history	Cloud backup service	IT Manager	Export	CT-04
E-07	Restore test reports	IT operations records	IT Manager	Document	CT-04
E-08	Training completion report	Awareness training platform	HR Manager	Export	CT-05
E-09	List of new joiners and leavers in the period	HR system	HR Manager	List	CT-05, CT-06
E-10	Account disable logs	Identity platform audit log	IT Manager	Export	CT-06
E-11	Offboarding checklists	HR records	HR Manager	Document	CT-06
E-12	Asset inventory	Device management platform	IT Manager	Export	CT-07, CT-08
E-13	EDR console export with last check-in dates	Endpoint security console	IT Manager	Export	CT-07
E-14	Encryption compliance report	Device management platform	IT Manager	Export	CT-08

Test Results

Design and operating effectiveness are concluded separately, because a control can be well designed and still fail in operation.

#	Control	Population	Sample tested	Exceptions raised	Design conclusion	Operating effectiveness conclusion	Overall conclusion	Notes
CT-01	A.8.2 / A.8.5 — Privileged accounts MFA	12	12	3	Effective with exceptions	Effective with exceptions	Effective with exceptions	Design: MFA is required for privileged access, but the policy does not define which authentication methods are acceptable. Operating: three exceptions — one admin account registered with SMS (not phishing-resistant), one service account without MFA, one break-glass account absent from the MFA report. The comparison step was executed with the Python script; output retained as evidence.
CT-02	A.8.5 — MFA for all users	85	15	0	Effective	Effective	Effective	Design: the conditional access policy covers all users with no unmanaged exclusions. Operating: all sampled accounts were registered for MFA.
CT-03	A.5.18 — Access rights review	4	2	1	Not effective	Not tested — design deficiency	Not effective	Design: no documented review procedure exists; reviews are performed ad-hoc without defined reviewers or evidence requirements. Operating-effectiveness testing was not completed: records for the sampled quarters were requested and could not be produced. Limited evidence was reviewed only to understand the deficiency.
CT-04	A.8.13 — Information backup	4	2	0	Effective	Effective	Effective	Design: the backup policy defines schedule, retention and restore testing. Operating: backup jobs completed as scheduled; restore tests performed and documented for both sampled quarters.
CT-05	A.6.3 — Awareness training	85	15	1	Effective	Effective with exceptions	Effective with exceptions	Design: the training policy defines the 30-day requirement for new joiners. Operating: one new joiner completed training 47 days after start date.
CT-06	A.5.11 — Return of assets and access removal	14	10	1	Effective with exceptions	Effective with exceptions	Effective with exceptions	Design: the offboarding process exists but account disabling depends on a manual notification from HR to IT, with no defined timeframe. Operating: one leaver account remained enabled for 5 working days after the termination date. Asset return was documented for all sampled leavers.
CT-07	A.8.7 — Malware protection coverage	92	92	1	Effective with exceptions	Effective with exceptions	Effective with exceptions	Design: EDR deployment is defined, but there is no monitoring or alerting on agent health. Operating: three endpoints had not reported to the EDR console within 14 days. All three were laptops of staff on extended leave.
CT-08	A.8.24 / A.7.9 — Endpoint encryption	92	92	0	Effective	Effective	Effective	Design: encryption is required by policy and enforced through device management. Operating: all managed endpoints reported encryption enabled.

Conclusion criteria

Effective	Design adequate and no material operating exceptions identified.
Effective with exceptions	Design adequate, but limited deviations were found that do not invalidate the control overall.
Not effective	Design is inadequate, or operating deviations are significant or frequent enough to prevent reliance on the control.
Not tested — design deficiency	Operating-effectiveness testing not completed because the design weakness makes a conclusion on effectiveness meaningless until it is addressed.

'Exceptions raised' counts exception records, not individual deviating items: one record may cover several items (for example CT-07, where three endpoints were affected by the same deficiency). Each record is tracked on the 'Exceptions and Remediation' sheet.

CT-01 was executed with a Python script (mfa_privileged_check.py in this repository). The script automates the comparison step only; the tester validated the input data, investigated the exceptions and reached the conclusion. The script output is retained as evidence and the test can be re-run with the same inputs.

All populations, samples, evidence and test results are fictional. This deliverable demonstrates the control-testing methodology; it does not represent testing performed on a real Microsoft 365 or Azure environment, and no conclusion here should be read as an audit opinion.

Exceptions and Remediation

Every exception is recorded with its root cause, remediation, owner and target date, and linked to the Risk Register (Deliverable 01).

#	Test	Exception description	Severity	Root cause	Remediation	Owner	Target	Related risk
X-01	CT-01	Admin account adm.tmayer is registered with SMS as its MFA method, which is not phishing-resistant and is not accepted for privileged access.	Medium	The MFA policy does not specify which authentication methods are acceptable for privileged accounts.	Define accepted methods for privileged access (FIDO2 or certificate-based) in the MFA policy and re-enroll the account on a FIDO2 security key.	IT Manager	Q3 2026	R-02
X-02	CT-01	Service account svc.backup has no MFA enabled.	High	Service accounts were excluded from the MFA rollout without a documented compensating control.	Migrate the account to a managed identity, or document a compensating control (restricted source IP, credential rotation) and formally retain the residual risk with a named approver.	IT Manager	Q3 2026	R-02
X-03	CT-01	Break-glass account brk.emergency does not appear in the MFA enrollment report.	High	The account was created outside the standard provisioning process and is not covered by the reporting scope.	Bring the account into the identity governance scope, apply a phishing-resistant method and document the break-glass procedure with monitoring of its use.	CISO	Q3 2026	R-02
X-04	CT-03	No documented access review procedure; quarterly reviews are performed ad-hoc and without records.	High	Access reviews were introduced informally and never formalized into a procedure with evidence requirements.	Define the quarterly access review procedure, assign reviewers and retain signed records.	CISO	Q4 2026	R-02, R-08
X-05	CT-05	One new joiner completed awareness training 47 days after start date (requirement: 30 days).	Low	Training assignment is manual and was not triggered at onboarding.	Add training assignment to the onboarding checklist and monitor completion monthly.	HR Manager	Q3 2026	R-03
X-06	CT-06	One leaver account remained enabled for 5 working days after the termination date.	Medium	Account disabling depends on a manual notification from HR to IT, with no defined timeframe.	Trigger account disabling from the HR termination record and verify within 24 hours.	IT Manager	Q4 2026	R-08
X-07	CT-07	Three endpoints had not reported to the EDR console within 14 days.	Low	No alerting on stale EDR agents; devices belonged to staff on extended leave.	Configure an alert for endpoints not reporting for more than 14 days and define a follow-up process.	IT Manager	Q4 2026	R-04

Exceptions are not closed by the tester: each one is remediated by the control owner, or formally retained by management with a documented rationale, an approver and a review date, as for the retained risks in Deliverable 01.

An exception is not automatically an ISO/IEC 27001 nonconformity. Exceptions are evaluated against the test criteria and assessed for significance before being reported as control deficiencies or nonconformities.

Control Testing — Summary

Version 2.0 — all values calculated automatically (COUNTIF) from the Test Results and Exceptions sheets.

Controls tested	8
BY DESIGN CONCLUSION	
Effective	4
Effective with exceptions	3
Not effective	1
BY OPERATING EFFECTIVENESS CONCLUSION	
Effective	3
Effective with exceptions	4
Not tested — design deficiency	1
BY OVERALL CONCLUSION	
Effective	3
Effective with exceptions	4
Not effective	1
EXCEPTIONS BY SEVERITY	
High	3
Medium	2
Low	2
Total exceptions	7

The three High exceptions all relate to privileged access (R-02), one of the two High residual risks in the Risk Register. Testing confirmed the risk assessment rather than contradicting it.

CT-03 failed at design stage: the control was described as quarterly in the SoA but no procedure or records exist. This is consistent with the SoA (Deliverable 02), which marks A.5.18 as partially implemented.

CT-01 exceptions concern authentication method strength and coverage of non-standard accounts, not the absence of MFA for users: MFA and Conditional Access are enforced for all user accounts in the defined scenario. The gap is that privileged accounts are not yet on phishing-resistant methods, and that service and break-glass accounts sit outside the standard enrollment scope.